Note de sécurité – Messagerie souveraine de l'administration

1. Ce que nous protégeons, et contre qui

Les échanges des agents (messages et fichiers, en individuel ou en groupe) contre : une écoute du réseau, un serveur ou un administrateur système curieux ou compromis, une personne extérieure qui tente d'entrer, un agent qui a quitté son poste, un téléphone perdu, la diffusion d'un document classifié à un agent non habilité, et la dépendance à un service étranger. Tous les tests portent sur des **comptes fictifs** ; aucun système réel n'est visé.

2. Chiffrement : un protocole éprouvé, rien de « maison »

- **Matrix Olm / Megolm**, implémenté par **vodozemac** (Rust, audité publiquement en 2022), intégré aux applications Element et à la bibliothèque `matrix-js-sdk`. Olm (double ratchet, Curve25519, signatures Ed25519) transporte les clés entre appareils ; Megolm chiffre les messages de salon (**AES-256**, intégrité **HMAC-SHA-256**).
- Les clés sont créées et gardées **sur les appareils** ; le serveur ne stocke que du texte chiffré. Quand un membre quitte un salon, les applications créent une **nouvelle clé de session** : un agent révoqué ne peut pas lire les messages suivants.
- **L'équipe n'a écrit aucun code cryptographique.** Le seul calcul HMAC de notre code est celui imposé par l'API officielle de Synapse pour créer le compte technique de la console.
- **Le serveur refuse le clair** (module `synapse/securite_messagerie`) : tout `m.room.message`, sticker ou sondage non chiffré est rejeté (403) ; un salon ne peut ni être créé sans chiffrement ni perdre son chiffrement (seul Megolm est accepté). Tous les salons sont chiffrés dès leur création.
- Transport : HTTPS (Caddy) avec une **autorité de certification interne** ; aucun appel à Let's Encrypt ni à un autre service extérieur.

3. Mesures contre chaque menace

Menace	Mesures	Vérifié par
Lecture par le serveur	Chiffrement de bout en bout ; refus du clair ; notifications sans contenu	`test_2_chiffrement.py` (texte cherché dans **toutes** les tables)
Intrus, inscription sauvage	Pas d'inscription, pas d'invités, pas de connexion par mot de passe Matrix : **SSO Keycloak seul** ; il faut être dans le groupe `agents`	`test_1_acces.py`
Vol de mot de passe, hameçonnage	**TOTP obligatoire** (norme ouverte RFC 6238, code calculé hors ligne par une application libre : FreeOTP, Aegis, que l'administration peut recompiler et distribuer elle-même ; pas de SMS) ; code utilisable une seule fois ; PKCE sur l'échange OIDC	`test_second_facteur_exige`
Essais en série	Keycloak verrouille après 5 échecs (1 min puis jusqu'à 15 min) ; limites de débit Synapse	configuration du royaume
Départ d'un agent	**Révocation** : compte désactivé, sessions fermées (Keycloak prévient Synapse par déconnexion *back-channel*), appareils supprimés, retrait des salons, en une à deux secondes	`test_revocation_immediate_sur_tous_les_appareils`
Téléphone perdu ou volé	**Bouton d'urgence** : appareils déconnectés, second facteur supprimé, nouveau mot de passe provisoire remis en main propre	`test_bouton_urgence_telephone_perdu`
Fuite vers un non-habilité	Salons `[CONFIDENTIEL]` réservés au groupe `habilites-confidentiel` (invitation et entrée refusées), déclassement interdit, conservation plafonnée	`test_3_classification.py`

Menace	Mesures	Vérifié par
Attaque de la console	Rôle `administrateur-securite` + TOTP ; jeton CSRF ; cookies `Secure`, `HttpOnly`, `SameSite` ; session de 30 min ; CSP sans script ; pas d'auto-révocation	`test_5_console.py`
API d'administration exposées	Bloquées par Caddy (404) ; console Keycloak sur `127.0.0.1` uniquement	`test_api_administration_non_exposees`
Dépendance à un tiers	Pas de fédération, pas de serveur de clés tiers, pas de statistiques, pas d'aperçu de liens, pas de Jitsi ni d'intégrations, pas de SMS : **réseau Docker interne sans Internet**	`test_federation_desactivee`, `docker-compose.yml`
Logiciel modifié	Versions figées ; Element vérifié par empreinte SHA-256 à la construction	`caddy/Dockerfile`

Chaque refus du serveur, connexion refusée et action d'administration est inscrit au **journal de sécurité** (console), **sans jamais le contenu des messages**.

4. Métadonnées : ce que le serveur voit encore, et ce que nous en faisons

Donnée	Visible par le serveur	Durée de conservation / mesure
Contenu des messages et fichiers	**Non** (chiffré)	—
Expéditeur, salon, heure d'un message	Oui	365 jours par défaut ; **30 jours** en DIFFUSION RESTREINTE, **7 jours** en CONFIDENTIEL (purge automatique)
Nom, sujet et membres d'un salon	Oui (non chiffrés par Matrix)	Consigne : aucune information sensible dans un nom de salon
Adresse IP et type d'appareil	Oui	**1 jour** ; journal d'accès HTTP non conservé
Présence (en ligne / hors ligne)	**Désactivée**	—
« En train d'écrire »	Non par défaut	Désactivé dans Element
Contenu des notifications	**Non** : « nouveau message » seulement	—
Profils et annuaire	Agents connectés uniquement	Profils inaccessibles sans connexion
Messages supprimés, salons abandonnés par tous	Oui	Effacés du serveur après **1 jour**
Connexions (Keycloak)	Oui	**30 jours**, pour détecter les intrusions

5. Limites connues (honnêtement)

- **Confiance dans les appareils** : un serveur compromis pourrait tenter d'ajouter un faux appareil à un agent. Element l'affiche (bouclier rouge « appareil non vérifié ») ; les agents doivent **vérifier** leurs sessions (QR code ou émojis). Étape suivante : n'envoyer les clés qu'aux appareils vérifiés.
- **Notifications** : le serveur ne peut joindre aucun service de notification extérieur (réseau interne). Android fonctionne en synchronisation d'arrière-plan (ou, à ajouter, avec un service UnifiedPush hébergé par l'administration) ; sur iPhone, les notifications instantanées exigeraient les services de l'éditeur de l'application et d'Apple (contenu jamais transmis).
- **Certificats** : l'autorité interne doit être installée sur chaque appareil ; en production, utiliser l'infrastructure de clés de l'État.
- Une capture d'écran ou un transfert volontaire par l'agent ne peut pas être empêché techniquement.
- La classification repose sur le **nom** du salon (visible par le serveur, comme tout nom de salon).
- Prototype sur une seule machine : pas encore de sauvegarde chiffrée, de haute disponibilité ni d'audit externe.